

Clase 289 — Privacidad y protección de datos

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *GDPR, ISO/IEC 27701 y NIST Privacy Framework* 

Duración estimada: **100 min** · Nivel: **Intermedio**

Objetivo

Profundizar en la privacidad como disciplina propia, más allá del cumplimiento legal de la clase 281. Al terminar entenderás los principios de *privacy by design*, la diferencia entre seguridad y privacidad, cómo ejecutar una Evaluación de Impacto de Protección de Datos (DPIA/EIPD), aplicar técnicas de minimización, seudonimización y anonimización, y el papel del DPO (Delegado de Protección de Datos).

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** privacidad de seguridad y por qué se necesitan ambas.
2. **Aplicar** los principios de *privacy by design* y *by default*.
3. **Ejecutar** una DPIA/EIPD de un tratamiento de alto riesgo.
4. **Diferenciar** seudonimización, anonimización y minimización.
5. **Atender** los derechos de los interesados y el papel del DPO.

Temas

#	Tema	Por qué importa
1	Privacidad vs. seguridad	Puedes ser seguro y aun así invadir la privacidad
2	Principios GDPR (Art.5)	Base de todo tratamiento lícito
3	Privacy by design & by default	La privacidad se diseña, no se parchea
4	DPIA / EIPD	Evaluar riesgo para los derechos de las personas
5	Minimización, seudonimización, anonimización	Reducir el dato reduce el riesgo
6	Derechos del interesado	Acceso, supresión, portabilidad, oposición
7	El DPO y la rendición de cuentas	Responsable de vigilar el cumplimiento

Definiciones y características

- **Privacidad:** derecho de las personas a controlar sus datos personales. *Clave:* protege a la persona, no solo al dato.
- **Privacy by design:** incorporar la privacidad desde el diseño del sistema. *Clave:* proactivo, no reactivo.
- **Privacy by default:** la configuración más protectora es la predeterminada. *Clave:* el usuario no debe "activar" su privacidad.

- **DPIA/EIPD**: evaluación del impacto de un tratamiento sobre los derechos y libertades. *Clave*: obligatoria en tratamientos de alto riesgo (GDPR Art.35).
- **Seudonimización**: sustituir identificadores de forma reversible con clave separada. *Clave*: sigue siendo dato personal.
- **Anonimización**: hacer imposible la reidentificación. *Clave*: deja de ser dato personal (fuera de GDPR) si es irreversible.
- **DPO (Delegado de Protección de Datos)**: figura independiente que supervisa el cumplimiento. *Clave*: obligatorio en ciertos casos (Art.37).

Herramientas y preparación

- Texto del GDPR (arts. 5, 25, 32, 35) y guías de la AEPD/EDPB sobre DPIA.
- Referencia de marcos: *ISO/IEC 27701* (PIMS) y *NIST Privacy Framework 1.0*.
- Una plantilla de DPIA (la AEPD y el ICO publican plantillas gratuitas).
- Para el laboratorio técnico: un pequeño dataset de ejemplo y Python con `pandas` para practicarseudonimización/anonimización.

Laboratorio guiado (ejercicio aplicado)

Parte A — DPIA de un nuevo tratamiento en "Ferretería del Sur S.A.":

1. **Escenario**: la empresa quiere implantar recomendaciones personalizadas basadas en el historial de compras y la ubicación.
2. **Descripción del tratamiento**: documenta finalidad, categorías de datos, base de licitud, destinatarios y plazos de conservación.
3. **Necesidad y proporcionalidad**: justifica si el tratamiento es necesario y proporcionado, o si podrías lograr el fin con menos datos (minimización).
4. **Identificación de riesgos**: lista 4 riesgos para los derechos de las personas (perfilado invasivo, reidentificación, brecha, uso secundario) con probabilidad e impacto.
5. **Medidas**: define controles para cada riesgo (consentimiento granular,seudonimización, retención limitada, opción de exclusión).
6. **Conclusión**: decide si el riesgo residual es aceptable o si debes consultar a la autoridad de control.

Parte B — Técnicas de reducción de dato (Python):

7. Con un dataset de ejemplo (nombre, email, ciudad, importe), aplicaseudonimización con hash yanonimización por generalización:

```
import pandas as pd, hashlib
df = pd.DataFrame({"email":["ana@x.com","luis@y.com"], "ciudad":["Sevilla","Sevilla"], "importe": [150, 250]})
# Seudonimización (reversible con clave separada; aquí hash como demo)
df["email_seudo"] = df["email"].apply(lambda e: hashlib.sha256(e.encode()).hexdigest()[:12])
# Minimización: elimina el identificador directo
df_min = df.drop(columns=["email"])
# Generalización para anonimizar el importe en rangos
df_min["rango_importe"] = pd.cut(df_min["importe"], bins=[0,100,200,500], labels=["bajo","medio","alto"])
print(df_min)
```

8. Explica por qué el hash simple no es anonimización real (riesgo de reidentificación por diccionario) y qué añadirías (sal, k-anonimato).

Parte C — Derechos:

9. Redacta el procedimiento para atender un derecho de acceso y uno de supresión en los plazos del GDPR (1 mes).

Ejercicios

1. Explica con un ejemplo la diferencia entre seguridad y privacidad.
2. ¿Cuándo es obligatoria una DPIA? Da dos criterios del Art.35.
3. Diferencia seudonimización de anonimización y su efecto legal.
4. Diseña la configuración "by default" de una app de mensajería respetando la privacidad.
5. ¿Por qué un hash sin sal no anonimiza un email? Propón la mejora.
6. Enumera 4 derechos del interesado y el plazo para atenderlos.

Reto verificable

Entrega una **DPIA completa** del tratamiento de recomendaciones personalizadas, con descripción, análisis de necesidad/proporcionalidad, identificación y evaluación de al menos 4 riesgos, medidas por riesgo y conclusión sobre el riesgo residual, más una demostración técnica de seudonimización y minimización sobre un dataset.

Criterio de aceptación: la DPIA justifica la minimización de datos, cada riesgo tiene una medida asociada, la conclusión indica si el riesgo residual es aceptable, y la demo distingue correctamente seudonimización de anonimización.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Confundir seguridad con privacidad	Cifrar no basta; hay que limitar finalidad y minimizar
"Anonimizar" con un simple hash	Es seudonimización reversible; usa sal, k-anonimato o supresión
Recoger "por si acaso" más datos de los necesarios	Viola minimización; recoge solo lo imprescindible
DPIA hecha después de lanzar	Privacy by design exige hacerla antes; incorpórala al diseño
Ignorar los plazos de derechos	GDPR da 1 mes; ten procedimientos listos

Preguntas frecuentes

? ¿Seguridad y privacidad no son lo mismo? No. La seguridad protege el dato de accesos no autorizados; la privacidad protege a la persona de usos indebidos, incluso por parte de quien tiene acceso legítimo. Se necesitan ambas.

? **¿Cuándo necesito un DPO?** Cuando el tratamiento a gran escala de datos sensibles o la monitorización sistemática lo requieran (GDPR Art.37), o si eres autoridad pública. Muchas empresas lo designan por prudencia.

? **¿La anonimización saca los datos del GDPR?** Sí, si es irreversible de verdad. Pero anonimizar bien es difícil; la seudonimización, en cambio, sigue siendo dato personal regulado.

? **¿Qué diferencia hay entre ISO 27701 y el NIST Privacy Framework?** 27701 extiende el SGSI de 27001 a la privacidad (certificable); el NIST Privacy Framework es un marco voluntario de gestión de riesgo de privacidad, análogo al CSF.

Referencias

- GDPR — Reglamento (UE) 2016/679, arts. 5, 25, 32, 35. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- ISO/IEC 27701:2019 — Privacy Information Management. <https://www.iso.org/standard/71670.html>
- NIST Privacy Framework 1.0. <https://www.nist.gov/privacy-framework>
- AEPD — Guías y plantillas de DPIA. <https://www.aepd.es/>
- (ISC)² CISSP Official Study Guide, dominio 2.

Siguiendo clase

Clase 290 - Certificaciones y desarrollo de carrera